

STAGE 3

Code reachability with Codeql:

```
SRC="/home/user01/solr-8.11.0/solr-source"
```

```
R="/home/user01/solr-8.11.0/results_codeql"
```

```
Q="$R/queries"
```

```
DB="$R/solr-codeql-db"
```

```
mkdir -p "$R" "$Q"
```

```
cd "$SRC"
```

```
rm -rf "$DB"
```

Create a database:

```
codeql database create "$DB" \
```

```
--language=java \
```

```
--source-root "$SRC" \
```

```
--build-mode=none
```

Codeql query pack:

```
cat > "$Q/qlpack.yml" <<'EOF'
```

```
name: local/solr-log4shell-queries
```

```
version: 0.0.1
```

```
dependencies:
```

```
  codeql/java-all: "*"
EOF
```

Codeql pack install:

```
cd "$Q"

codeql pack install

cd "$SRC"
```

Query 1 Direct call to Jndilookup.lookup():

```
cat > "$Q/find-jndilookup-direct-call.ql" <<'EOF'

/**

 * @name Direct calls to JndiLookup.lookup

 * @description Finds direct source-level calls to
org.apache.logging.log4j.core.lookup.JndiLookup.lookup.

 * @kind problem

 * @problem.severity warning

 * @id java/log4shell/direct-jndilookup-call

 */

import java

from MethodCall call, Method target

where

  call.getMethod() = target and
  target.getName() = "lookup" and
  target.getDeclaringType().hasQualifiedName(
    "org.apache.logging.log4j.core.lookup",
    "JndiLookup"
  )

select call, "Direct call to JndiLookup.lookup()."
```

EOF

```
codeql query run "$Q/find-jndillookup-direct-call.ql" \  
  --database="$DB" \  
  --output="$R/jndillookup-direct-call.bqrs"
```

```
codeql bqrs decode "$R/jndillookup-direct-call.bqrs" \  
  --format=csv \  
  --output="$R/jndillookup-direct-call.csv"
```

```
cat "$R/jndillookup-direct-call.csv"
```

Query2 direct reference to jndillookup:

```
cat > "$Q/find-jndillookup-type-reference.ql" <<'EOF'  
  
/**  
  
 * @name Direct references to JndiLookup type  
  
 * @description Finds direct source-level references to  
org.apache.logging.log4j.core.lookup.JndiLookup.  
  
 * @kind problem  
  
 * @problem.severity warning  
  
 * @id java/log4shell/jndillookup-type-reference  
  
 */
```

```
import java
```

```
from TypeAccess access, RefType t
```

```
where
```

```
access.getType() = t and
t.hasQualifiedName(
  "org.apache.logging.log4j.core.lookup",
  "JndiLookup"
)
select access, "Direct reference to JndiLookup type."
EOF
```

```
codeql query run "$Q/find-jndillookup-type-reference.ql" \
--database="$DB" \
--output="$R/jndillookup-type-reference.bqrs"
```

```
codeql bqrs decode "$R/jndillookup-type-reference.bqrs" \
--format=csv \
--output="$R/jndillookup-type-reference.csv"
```

```
cat "$R/jndillookup-type-reference.csv"
```